

# Unifolio — Data Retention & Deletion Policy

**Effective date:** 2026-05-13

**Last reviewed:** 2026-05-13

**Owner:** Ahmed Al-Samak, CEO (security@unifolio.ca)

**Review cadence:** Annually, or upon material change to data architecture or applicable privacy law.

## 1. Purpose

This policy defines how long Unifolio retains each category of user data, when and how that data is deleted, and how deletion is verified. It implements the retention commitments made in our **PRIVACY\_POLICY.md** and ensures compliance with PIPEDA (Canada), GDPR (EU/UK), and the Plaid Production Customer Agreement.

## 2. Data classes and retention schedule

| Data class            | Examples                                                                | Retained while account active? | Retention after deletion request                                                                                                                                                                            | Backup retention                                    |
|-----------------------|-------------------------------------------------------------------------|--------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| Account identity      | Email, name, password hash, profile photo                               | Yes                            | Hard-deleted within <b>24 hours</b>                                                                                                                                                                         | Cycled out of nightly backups within <b>30 days</b> |
| Portfolio data        | Holdings, transactions, realized positions, custom assets, ACB history  | Yes                            | Hard-deleted within <b>24 hours</b>                                                                                                                                                                         | 30 days                                             |
| Plaid connection data | <code>item_id</code> , <code>access_token</code> , institution metadata | Yes                            | Database record hard-deleted within <b>24 hours</b> . Active <code>access_token</code> revocation via Plaid <code>/item/remove</code> happens immediately when the user explicitly disconnects an Item from | 30 days                                             |

| Data class                      | Examples                                       | Retained while account active?                                     | Retention after deletion request                                                                                                                                  | Backup retention         |
|---------------------------------|------------------------------------------------|--------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
|                                 |                                                |                                                                    | Settings; cascading revocation on full-account deletion is a Q3 2026 roadmap item (currently the user is prompted to disconnect Items prior to account deletion). |                          |
| <b>Imported broker files</b>    | Raw CSV/Flex/PDF uploads                       | <b>Never stored</b> — only parsed positions/transactions are saved | N/A                                                                                                                                                               | N/A                      |
| <b>Profile picture asset</b>    | Image file in Supabase Storage                 | Yes                                                                | Deleted from Storage immediately on account deletion                                                                                                              | 30 days                  |
| <b>Transient session data</b>   | Auth tokens, session cookies                   | Until user signs out or 7-day session timeout                      | Cleared immediately on sign-out                                                                                                                                   | N/A                      |
| <b>Audit logs</b>               | Sign-ins, deletion timestamps, security events | Yes                                                                | Retained <b>90 days</b> post-deletion (security obligation), then permanent purge                                                                                 | 90 days                  |
| <b>Email correspondence</b>     | Support emails, password reset emails          | Stored in Microsoft 365 mailbox                                    | Anonymized or deleted on user request                                                                                                                             | Per Microsoft 365 policy |
| <b>Marketing opt-in records</b> | Subscriber list (if applicable)                | Until unsubscribe + 30-day suppression list                        | Removed within 30 days of unsubscribe                                                                                                                             | N/A                      |

## 3. Deletion mechanism

### 3.1 User-initiated deletion (self-service)

Users can permanently delete all their data via:

**Settings → Privacy & Data → Delete All Data**

The flow: Data Retention and Disposal Policy · Unifolio Inc. · Generated 2026-05-13 · Canonical version: [github.com/2uay/unifolio](https://github.com/2uay/unifolio)

1. User confirms deletion via a 2-step modal ( `DeleteConfirmModal` in `src/pages/PrivacyAndData.jsx` ) with a checkbox confirming the action is irreversible.
2. The frontend calls the `delete_unifolio_user_data` Postgres RPC (defined in `supabase/schema.sql` ), which executes inside a single transaction:
  - Hard-delete from: `holdings` , `transactions` , `realized_positions` , `custom_assets` , `import_batches` , `watchlist` , `accounts` , `plaid_items` , `institutions` (those orphaned), `user_profiles` .
  - Auth user record deletion via `auth.users` cascade.
  - Profile picture asset deletion from Supabase Storage `avatars` bucket.
1. **Plaid `access_token` revocation:** when a user explicitly disconnects a Plaid Item from Settings, Unifolio calls Plaid's `/item/remove` immediately, terminating the connection at both the Unifolio and the bank end. On full-account deletion (the path above), the database record holding the access token is hard-deleted within 24 hours, but the active token revocation against Plaid's API on full-account-delete is a roadmap item targeted for Q3 2026. Until then, users are prompted to disconnect Plaid Items prior to triggering account deletion.
2. Local browser caches (theme, currency, watchlist, profile picture cache) are cleared by the frontend.
3. A deletion audit row is written to `audit_log` (see §3.4) with the user ID and timestamp; **no other PII** is logged.

### 3.2 Account-level deletion (Accounts page)

Users can delete an individual account (one brokerage) without deleting their full Unifolio profile. This:

- Cascades through the account's `holdings` , `transactions` , `realized_positions` , `import_batches` .
- Prunes the parent `institution` row if no other accounts reference it (handled by the `delete_unifolio_account` RPC).
- Revokes the relevant Plaid `access_token` if the account was Plaid-connected.

### 3.3 Inactive-account expiry

Currently we do **not** auto-delete inactive accounts. If we introduce auto-expiry in future, we will:

- Notify the user 30 days before deletion via email.
- Default to a 24-month-of-inactivity threshold.
- Update this policy and notify users of the change.

### 3.4 Audit log

Deletion events are written to an `audit_log` table containing only:

- `event_type` ("account\_deletion", "data\_export", "plaid\_token\_revoke", etc.)

- `user_id` (UUID; not the email or name)
- `timestamp`
- `actor` ("self" | "ops")

These records are retained **90 days** for security and compliance investigation, then permanently purged by a scheduled cleanup query.

---

## 4. Backup retention

---

Supabase performs **automated nightly backups** of the entire Postgres database with **point-in-time recovery (PITR)** for the last 7 days. After a deletion request:

- The deleted record is gone from the **live database** within 24 hours.
- It may persist in **encrypted backup snapshots** for up to **30 days** before backup rotation purges it.
- Backup data is **only ever accessed for disaster recovery** and is never used for normal queries.

If a user explicitly requests their data be removed from backups before the 30-day window (a rare GDPR request), we will document the request and confirm completion within an additional 30 days.

---

## 5. Plaid-specific retention

---

Per the Plaid Production Customer Agreement:

- Plaid `access_token` revocation via `/item/remove` is performed immediately when the user explicitly disconnects an Item from Settings.
  - On full account deletion, the database row containing the access token is hard-deleted within 24 hours. Calling `/item/remove` against Plaid's API as part of the cascade is a roadmap item (Q3 2026) — currently the user-facing flow prompts the user to disconnect Plaid Items prior to triggering account deletion.
  - Plaid `item_id` and institution metadata are deleted from our database within 24 hours of any deletion request.
  - Cached Plaid account/transaction data is deleted alongside the rest of the user's portfolio data.
  - Unifolio retains no Plaid Link credentials at any point — Plaid handles all underlying broker authentication.
- 

## 6. Export rights

---

Before deletion, users can export their full data via:

**Settings → Privacy & Data → Export your data**

Exports include:

- Full JSON dump of all portfolio data
- Holdings CSV
- Transactions CSV
- Realized gains CSV

These are generated client-side from the user's own data and downloaded directly to their device — no copy is created on our servers.

---

## 7. Verification & monitoring

---

- After every account-deletion request, the CEO spot-checks the `audit_log` weekly to confirm deletion events succeeded and no orphaned records remain.
- A quarterly query is run to detect any potential orphans:

```
```sql
-- Holdings without a matching auth.users row
SELECT COUNT(*) FROM holdings h
LEFT JOIN auth.users u ON u.id = h.user_id
WHERE u.id IS NULL;
```
```

- Any orphaned rows discovered are deleted manually within 7 days and the deletion query is re-run to confirm.
- 

## 8. Records of processing

---

Per GDPR Article 30, Unifolio maintains records of processing activities. These are documented in:

- **PRIVACY\_POLICY.md** — public-facing summary
- **INFOSEC\_POLICY.md** — internal vendor + data-flow inventory
- This document — retention specifics

The combined set is reviewed annually by the CEO.

---

## 9. Policy changes

---

This policy is reviewed and updated:

- **Annually** at minimum.

- **On any material change** to deletion procedures, retention windows, or applicable regulation.

The change history is the Git commit history of this file in the public Unifolio repository.

---

## Acknowledgement

---

— Ahmed Al-Samak, CEO, Unifolio Inc.

2026-05-13